PROCEDURE

Security of Development and Staging Web Environments

Document Reference	IT-SEC-002
Issuing Authority	Computer Services
Classification	Internal Use Only
Compliance Framework	Jamaica Data Protection Act (JDPA) 2020
Related Documents	Organisational IT/Cybersecurity Incident Response Plan
Version	2.0
Review Cycle	Annually or following a security incident
Applies To	CEO, Director/Deputy CEO, Security Officer, IT Manager, DPO, Webmaster, Web Developers, Approved Clients

DOCUMENT REVISION HISTORY

Version	Date	Author	Summary of Changes
1.0	March 2026	IT Manager	Initial issue
2.0	March 2026	IT Manager	Legal review — s.6.1 policy/statute distinction corrected; s.12 simplified to clean report-to-IT-Manager chain with full IRP handoff; redundant notification steps removed; s.12.1 IRP dependency clause added; s.8.3 JDPA lawful basis for log retention noted; version control corrected throughout

1. PURPOSE

This procedure establishes mandatory security requirements for the full lifecycle of all development (dev) and staging web environments hosted on organisational cPanel shared hosting infrastructure. It ensures that no dev or staging environment can become the source of a data breach, cybersecurity incident, or unauthorised disclosure of government or client information.

It applies to all environments provisioned in support of client websites managed by the Web Services Unit and is binding on all staff and approved clients who interact with these environments.

This procedure operates alongside the organisation's IT/Cybersecurity Incident Response Plan (IRP). Where a security event is identified, this procedure governs identification and immediate containment. The IRP governs all subsequent investigations, recovery, notification, and post-incident review. Where an incident involves personal data, the Data Protection Officer must be engaged immediately and in parallel with the technical response. The IRP must address at minimum: the JDPA notifiability risk assessment process and documentation, evidence preservation and log retention obligations during investigation, and the criteria for law enforcement referral under the Cybercrimes Act 2015. Where the IRP is silent on any of these matters, the obligations revert to this procedure and the DPO's independent judgement.

1A. DEFINITIONS

The following definitions apply throughout this procedure. Where a term is defined in the Jamaica Data Protection Act 2020, hereinafter referred to a JDPA that statutory definition applies.

Personal data: Data relating to a living individual who can be identified from that data, or from that data together with other information in the possession of or likely to come into the possession of the organisation, as defined in the JDPA 2020. This includes pseudonymised data, IP addresses, device identifiers, CMS user account data, and any data capable of identifying an individual in combination with other data held by the organisation.

Personal data breach: A breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, personal data transmitted, stored, or otherwise processed, as defined in the JDPA 2020.

Data controller: A person or organisation that, alone or jointly, determines the purposes and means of processing personal data. The organisation is the data controller for personal data it processes in its own right. Where it processes personal data on behalf of a client, that client is the data controller and the organisation acts as a data processor.

Data processor: A person or organisation that processes personal data on behalf of a data controller. Where the organisation acts as a data processor for client data, a written Data Processing

Agreement must be in place with that client confirming the organisation's processor obligations and the technical and organisational measures it maintains, of which this procedure forms a part.

Lawful basis: The legal ground under the JDPA 2020 that permits processing of personal data. Where live personal data is used in a dev/staging environment under Section 6.3, the DPO must confirm the lawful basis in writing before IT Manager approval is given. No live data exception may be approved without a confirmed lawful basis.

Synthetic data: Artificially generated data that replicates the statistical and structural characteristics of real data without containing any personally identifiable information. Informally anonymised real data does not qualify as synthetic data.

Effective Date: The date on which this procedure is signed by all required signatories in Section 17 and from which all obligations in this procedure become binding. Prior to that date this document is a draft and is not operative.

2. SCOPE

This procedure applies to:

- All development and staging environments created on cPanel shared hosting accounts owned or managed by the organisation
- All client websites hosted and managed by the organisation
- All web developers, the Webmaster, IT Manager, Security Officer, Data Protection Officer, Director/Deputy CEO, and CEO where escalation requires
- Any approved client granted conditional access to a staging environment
- Any environment — regardless of how temporary — that runs on organisational hosting infrastructure
- The third-party hosting provider relationship, to the extent defined in Section 15

3. ROLES AND RESPONSIBILITIES

3.1 Governance Structure

The full governance chain applicable to this procedure is as follows:

```
CEO  <-------- DPO (reports to CEO's Office — independent of IT chain)
```

```
|
+-- Director / Deputy CEO
        |
        +-- Security Officer (reports to Director)
        |
        +-- IT Manager (reports to Director)
                |
                +-- Webmaster (reports to IT Manager)
                |
                +-- Web Developers (report to IT Manager)
```

The CEO is the highest-ranking officer. The DPO reports to the CEO's Office and is fully independent of the operational IT chain. The Security Officer reports directly to the Director. The IT Manager reports to the Director. The Webmaster and all Web Developers report to the IT Manager. The Director and CEO are engaged in escalation and executive incident response only and do not participate in routine day-to-day procedure decisions.

3.2 CEO — Highest Organisational Authority

The CEO is the highest-ranking officer in the organisation. Under this procedure the CEO's role is:

- Receiving notification of any confirmed serious security incident or personal data breach escalated through the Director and/or DPO
- Being the ultimate decision-making authority where an incident requires executive action beyond the Director's level
- Providing the organisational context within which the DPO's independence is maintained — the DPO's reporting line to the CEO's Office ensures data protection obligations cannot be subordinated to operational priorities
- The CEO does not participate in routine environment approvals, access grants, or operational decisions under this procedure

3.3 Director / Deputy CEO — Executive Procedure Authority

The Director, who also holds the role of Deputy CEO, is the executive authority over this procedure. Responsibilities are:

- Approving and signing this procedure and all subsequent versions before they take effect
- Acting as escalation point when the IT Manager is unavailable and no deputy has been designated
- Being notified immediately of any confirmed or suspected security incident by the IT Manager
- Playing an active role in incident response and escalation above the IT Manager level in accordance with the Incident Response Plan
- Escalating to the CEO where an incident is of a severity requiring the CEO's involvement

- The Director does not authorise routine environment requests, access grants, or decommissioning decisions — these remain with the IT Manager

3.4 Security Officer — Cybersecurity and Technical Risk Authority

The Security Officer reports to the Director and is the organisation's independent cybersecurity and technical risk authority. The Security Officer does not sit within the IT Manager's chain of command, ensuring independence of security oversight. Responsibilities include:

- Conducting independent unannounced spot-checks on active dev/staging environments at least quarterly and reporting findings to the Director and IT Manager
- Reviewing all live data exception requests and providing a written technical risk recommendation to the IT Manager
- Leading the technical investigation of security incidents in accordance with the Incident Response Plan
- Immediately referring all personal data aspects of any incident to the DPO in parallel with the technical response
- Reviewing this procedure annually from a cybersecurity standpoint and recommending amendments
- Maintaining the organisation's risk register entry for dev/staging environment risk
- Approving and maintaining the synthetic data standard in consultation with the DPO
- Receiving copies of all Environment Register entries and incident reports
- Briefing the Director on security posture, active risks, and incidents as required

The Security Officer does not own JDPA compliance obligations — those sit exclusively with the DPO. Where cybersecurity and data protection overlap, the Security Officer and DPO work in coordination, each retaining authority in their respective lanes.

3.5 IT Manager — Operational Authority

The IT Manager reports to the Director and is the primary decision-maker for all routine activity under this procedure. No environment may be created, have access granted, or be decommissioned without the IT Manager's explicit written approval. Responsibilities include:

- Approving or declining all environment requests
- Approving all access grants including conditional client access
- Authorising decommissioning of all environments
- Formally signing off the Webmaster's provisioning checklist before any environment is handed to developers
- Signing off 30-day post-launch review outcomes
- Ensuring this procedure is enforced, trained upon, and reviewed annually

- Notifying the Director immediately upon becoming aware of any confirmed or suspected security incident
- Notifying the DPO immediately and in parallel upon becoming aware of any incident involving actual or suspected personal data
- Formally activating the Incident Response Plan when a security incident is identified
- Approving all formal exceptions or waivers to this procedure
- Managing the Webmaster and all Web Developers in day-to-day compliance with this procedure
- Designating a named deputy before any planned absence and notifying the Webmaster in writing

3.6 Deputy Authority — Absence Cover

Before any planned absence the IT Manager must designate a named deputy in writing and notify the Webmaster. The deputy holds the same routine approval authority for the duration of the absence with the following limitations:

- The deputy may not approve exceptions or waivers to this procedure
- The deputy may not make decisions on a live security incident beyond initial containment — the Director must be engaged immediately
- The deputy has no authority over the DPO's data protection functions — these remain with the DPO at all times
- If the absence is unplanned and no deputy has been designated, all pending approvals must be escalated to the Director until a deputy is formally nominated

3.7 Data Protection Officer — Independent JDPA Authority

The DPO is an internal staff member who reports to the CEO's Office. The DPO operates entirely independently of the IT chain. The DPO's authority on data protection matters cannot be directed or overridden by the IT Manager, Security Officer, Director, or any other operational role. The organisation must confirm whether DPO appointment is mandatory under the JDPA 2020 (required for public authorities and organisations conducting large-scale processing of personal data) or voluntary. Regardless, the DPO's independence and the prohibition on conflicting instructions must be protected not only by this procedure but in the DPO's contract of employment or formal terms of reference — a procedure alone cannot override a contract of employment. Responsibilities include:

- Owning all of the organisation's obligations under the Jamaica Data Protection Act 2020 in relation to dev/staging environments
- Being notified immediately whenever an incident involving actual or suspected personal data exposure occurs — this must happen in parallel with, not after, the technical incident response

- Independently assessing whether a personal data breach has occurred and determining notification obligations to the Office of the Information Commissioner of Jamaica
- Managing the statutory 72-hour notification window to the OICJ — the clock starts from the moment any staff member first becomes aware of a breach
- Providing an independent written data protection assessment on all live data exception requests before the IT Manager decides
- Reviewing this procedure annually from a data protection standpoint
- Maintaining records of all personal data processing activities in dev/staging environments
- Advising the Webmaster and developers on data protection requirements as they arise
- Escalating material data protection concerns directly to the CEO's Office, independent of the IT or operational chain
- The DPO does not provision environments, approve access, or authorise decommissioning

3.8 Webmaster — Operational Executor

The Webmaster reports to the IT Manager and carries out all operational and technical tasks related to dev/staging environments, acting only on the IT Manager's written approval. The Webmaster holds no independent authority to approve requests, grant access, or decommission environments. Responsibilities include:

- Receiving environment requests from developers and forwarding to the IT Manager with a technical assessment within 1 business day
- Provisioning all approved environments on cPanel in full compliance with this procedure
- Completing the provisioning checklist and submitting it to the IT Manager for formal sign-off
- Configuring and verifying all security controls prior to developer handover
- Granting and revoking all access on IT Manager instruction
- Maintaining and updating the Environment Register
- Conducting the 30-day post-launch review and presenting findings to the IT Manager
- Executing decommissioning upon IT Manager authorisation including DNS and certificate cleanup
- Retaining server access logs in accordance with Section 8.3
- Upon identifying a suspected incident: immediately notifying the IT Manager, who activates the Incident Response Plan
- Preserving all environment logs, files, and configurations without modification until the IT Manager instructs otherwise under the Incident Response Plan

3.9 Web Developers

Web developers report to the IT Manager and are the only staff authorised to initiate an environment request. Responsibilities include:

- Submitting complete environment requests using the approved request form (Appendix A) — verbal or informal requests will not be actioned
- Using only anonymised or synthetic data unless a live data exception has been explicitly approved in writing
- Never copying or restoring any production backup to a dev/staging environment without IT Manager approval
- Notifying the Webmaster in writing on the day a project goes live
- Notifying the Webmaster immediately when an environment is no longer needed
- Immediately reporting any suspected security issue, unexpected access, or accidental data exposure to the IT Manager — any suspected personal data exposure starts the 72-hour JDPA clock and must be reported without delay
- Completing mandatory training on this procedure before being granted access to any environment

3.10 Approved Clients — Conditional Access

Clients may be granted conditional, time-limited access to a staging environment for reviewing and approving work in progress. Clients are external parties with a defined, limited review role. Client access is subject to the following:

- Access must be requested by the assigned web developer and approved in writing by the IT Manager before any access is granted
- The client must be issued organisation-provisioned credentials — clients must never use shared or self-created credentials
- Client access must be read-only wherever technically feasible
- Client access must carry an explicit expiry date not exceeding 30 days without IT Manager renewal approval
- Client access must be fully recorded in the Environment Register
- The Webmaster must revoke client access immediately upon expiry or project sign-off, whichever comes first
- Clients must sign the Client Access Agreement (Appendix B) before access is granted
- Clients must be informed that the environment must not be shared with third parties or referenced publicly

3.11 Hosting Provider

The organisation procures shared cPanel hosting from a third-party provider. The security boundary is defined in Section 15. The Webmaster is responsible for maintaining the day-to-day relationship with the hosting provider, receiving and distributing security advisories to the relevant parties, and

escalating to the provider when a platform-level security issue is suspected. The IT Manager must be notified immediately whenever the Webmaster escalates an issue to the hosting provider. The Security Officer and DPO must both be notified of any advisory that may involve personal data or affect hosted environments.

4. PHASE 1 — ENVIRONMENT REQUEST AND APPROVAL

4.1 Who May Request

Only web developers may submit a request for a new dev or staging environment. No other staff, client, or external party may initiate this process.

4.2 Submitting a Request

The web developer must submit a completed Environment Request Form (Appendix A) to the Webmaster. Freeform requests are not acceptable. The form must capture:

- Project name and client
- Purpose of the environment
- Risk classification (see Section 4.3)
- Expected duration
- Whether a live data exception is anticipated
- Names and roles of all individuals requiring access
- Whether client access is required, the client contact, and required access level

4.3 Risk Classification

The Webmaster must assign one of the following risk classifications before forwarding to the IT Manager:

Classification	Criteria and Controls
STANDARD	No personal data anticipated, simple build or feature test, internal access only. Baseline controls apply.
ELEVATED	Involves replication of a data-heavy production feature, client access required, or potential for personal data to be present. All baseline controls apply. Security Officer and DPO must be notified before provisioning begins.
HIGH	Live data exception anticipated at the outset, or environment replicates a system processing sensitive personal data. IT Manager, Security Officer, and DPO must all provide written input before provisioning. Enhanced monitoring applies for the full duration.

4.4 Webmaster Assessment

The Webmaster must review the request for completeness, assign a risk classification, and forward to the IT Manager with a written technical assessment within 1 business day of receipt. For Elevated or High classifications, the Webmaster must simultaneously notify the Security Officer and DPO.

4.5 IT Manager Decision

The IT Manager must approve or decline in writing within 2 business days of receiving the Webmaster's assessment. If no decision is issued within 2 business days, the Webmaster must follow up in writing. If no decision is issued within 5 business days the matter must be escalated to the Director. All decisions must be retained on file permanently.

5. PHASE 2 — ENVIRONMENT PROVISIONING AND SETUP

The Webmaster must complete all steps in this phase and obtain formal IT Manager sign-off on the provisioning checklist before notifying the developer that the environment is ready.

5.1 Naming and Isolation

- Environments must be clearly named to distinguish them from production, e.g. dev-projectname or staging-projectname
- Each environment must be created on its own subdomain with a DNS record removed at decommissioning
- Dev and staging must never share a database, file storage, or credentials with production
- Separate cPanel credentials, database users, and file paths must be used per environment

5.2 Search Engine Blocking — MANDATORY

All three controls are mandatory and must be independently verified active before developer access is granted. Confirmation of one does not substitute for the others.

robots.txt — place in the root of every environment:

```
User-agent: *
Disallow: /
```

Meta noindex tag — in the <head> of every page:

```
<meta name="robots" content="noindex, nofollow">
```

CMS-level setting — the "discourage search engines" or equivalent setting must be enabled.

5.3 HTTP Basic Authentication

Every environment must be protected by HTTP Basic Authentication at the server level via .htaccess and .htpasswd, in addition to any CMS login. Passwords must be a minimum of 14 characters combining uppercase, lowercase, numbers, and symbols. Credentials must be unique per environment and must never reuse production credentials.

5.4 MFA on cPanel

MFA/2FA must be active on all developer cPanel accounts at all times. Any account without MFA must be suspended until confirmed active.

5.5 IP Restrictions

Access must be restricted to known organisational IP addresses wherever technically feasible. Any exception requires IT Manager written approval, must be time-limited, and must be recorded in the Environment Register.

5.6 SSL / HTTPS

All environments must run over HTTPS with HTTP automatically redirected. No environment accessible over unencrypted HTTP is acceptable under any circumstance.

5.7 Directory Listing

Directory listing must be disabled via cPanel settings or Options -Indexes in .htaccess on all environments.

5.8 File and Directory Permission Standards

Item	Required Permission
Directories	755
Files	644
Configuration files (e.g. wp-config.php)	600
World-writable (777)	**STRICTLY PROHIBITED**

5.9 Database Security

- Database names and usernames must not be predictable or obviously reflect the client or project
- Each environment must use a dedicated database user with minimum necessary privileges — no root or superuser access permitted
- Remote MySQL access must be disabled for all dev/staging database accounts
- Default database table prefixes must be changed at setup

5.10 CMS Hardening

Where a CMS is used the following are mandatory at provisioning:

- Default admin username must be changed to a non-guessable value
- All default installation credentials must be changed immediately
- CMS dashboard file editing must be disabled
- XML-RPC must be disabled unless explicitly required by the project
- Login attempt limiting must be enabled
- All unused themes and plugins must be deleted — not merely deactivated
- All CMS and plugin versions must be current at the time of provisioning

5.11 Outbound Email Restriction

Outbound email must be disabled or restricted on all dev/staging environments at provisioning. Where email testing is required a sandboxed email testing tool must be used. Live SMTP credentials pointing to a real mail server must never be configured in any dev/staging environment.

5.12 Debug Mode

Debug mode and verbose error display must be off on all publicly accessible environments. Errors must be written to a server-side log file only and must not display in the browser.

5.13 Provisioning Checklist and IT Manager Sign-Off

The Webmaster completes the checklist below and submits it to the IT Manager for formal written sign-off. The IT Manager's sign-off is mandatory — the environment must not be handed to the developer until it is received.

Control	Webmaster Verified	IT Manager Sign-Off
robots.txt — full Disallow in place		
Noindex meta tag verified on all pages		
CMS search engine discouragement enabled		
HTTP Basic Authentication active		
HTTPS enforced, HTTP redirects in place		
Directory listing disabled		
File permissions set (755 / 644 / 600)		
No world-writable files or directories		

Database isolated, minimum privilege user		
Remote MySQL access disabled		
Default DB table prefix changed		
CMS default credentials changed		
CMS admin username changed from default		
CMS file editing disabled		
XML-RPC disabled (if not required)		
Login attempt limiting active		
Outbound email disabled or sandboxed		
Debug mode off, errors log-only		
MFA active on all cPanel accounts		
IP restrictions applied or exception documented		
Database separate from production		
No live data present		
SSL certificate active and valid		
DNS record created and recorded in Register		

6. PHASE 3 — DATA HANDLING IN DEV/STAGING ENVIRONMENTS

6.1 Default Rule — No Live Data

No real, live, or personally identifiable data may exist in any dev or staging environment. All development and testing must use anonymised or synthetic data. This is a mandatory organisational policy standard, adopted because the JDPA 2020 requires that personal data is processed lawfully, fairly, and proportionately, with appropriate technical safeguards. Processing personal data in an uncontrolled non-production environment without documented lawful basis and approved safeguards would be inconsistent with those obligations. The prohibition on live data in dev/staging environments is therefore the organisation's internal standard implementing that legal principle — it is a stricter operational rule than the Act itself requires in absolute terms, and is maintained as such.

6.2 Prohibition on Restoring Production Backups

Developers must not download, copy, or restore any production backup — full or partial — to a dev/staging environment without the explicit prior written approval of the IT Manager. This includes cPanel full backups, database dumps, and file archives. Violation of this rule is a serious breach of this procedure regardless of whether data is subsequently exposed.

6.3 Exception — Live Data for Specific Issue Diagnosis

All of the following conditions must be satisfied before any live data may enter a dev/staging environment:

1. Developer submits a written request to the Webmaster explaining specifically why synthetic data cannot replicate the issue
2. Webmaster forwards to both the Security Officer and the DPO simultaneously for independent written assessments — both must respond before the request proceeds to the IT Manager
3. Security Officer provides a written technical risk recommendation to the IT Manager
4. DPO provides an independent written data protection assessment to the IT Manager
5. IT Manager provides explicit written approval having considered both recommendations — no data may be copied before this approval is received
6. Only the minimum data necessary may be used — full database restores are not permitted where a subset will suffice
7. Data must be deleted within 24 hours of the issue being resolved and no later than 48 hours after first being copied, whichever is sooner. Any extension beyond 24 hours must be approved in writing by the IT Manager with a documented reason, and notified to the DPO, who must record the extension as a separately justified retention period in the data processing records
8. Developer confirms deletion in writing to the Webmaster

9. Webmaster verifies deletion and records the full exception in the Environment Register
10. Both the Security Officer and DPO must receive a copy of the completed exception record

6.4 Synthetic Data Standard

The Security Officer, in consultation with the DPO, maintains the organisation's approved synthetic data standard defining acceptable tools and methods for generating realistic test data that carries no re-identification risk. Informally anonymised real data does not meet this standard. Approved methods are communicated through the mandatory training programme.

6.5 Jamaica Data Protection Act 2020 — DPO Ownership and 72-Hour Notification

The DPO owns all JDPA 2020 compliance obligations in relation to dev/staging environments. In the event of a confirmed or suspected breach the DPO must assess notification obligations to the Office of the Information Commissioner of Jamaica. The statutory notification window is 72 hours from the moment any staff member first becomes aware of the breach — not from when it is formally escalated internally.

Every staff member must understand that informal awareness of a potential breach starts this clock immediately. Early, prompt internal reporting is therefore a legal obligation. The DPO manages this obligation independently through the CEO's Office and cannot be directed to delay or withhold notification by any operational role.

7. PHASE 4 — ACCESS MANAGEMENT DURING THE ENVIRONMENT LIFECYCLE

7.1 Internal Developer Access

Access is granted only to developers named in the IT Manager's approved request. Each developer must have individually provisioned credentials — no shared credentials are permitted. If a developer is removed from a project, changes role, or leaves the organisation, the Webmaster must revoke their access within 24 hours of notification. The IT Manager must be notified of all revocations.

7.2 Joiners, Movers, and Leavers — HR Integration

- Leavers: HR or the line manager must notify the IT Manager and Webmaster on the same day a departure is confirmed. Access must be revoked within 24 hours from the confirmed departure date — not the last working day
- Movers: When a developer changes role or is reassigned, all environment access must be reviewed within 5 business days and any no longer required must be revoked
- Joiners: No developer may be granted environment access until mandatory training under Section 13 is documented as complete

7.3 Approved Client Access

- Client credentials must be provisioned by the Webmaster — not self-created by the client
- All client access activity must be logged and retained in accordance with Section 8.3
- Client access beyond 30 days requires a fresh IT Manager approval — access does not auto-renew
- Client credentials must be unique and must not be shared between clients or projects

7.4 Credential Rotation

Credentials must be rotated when any of the following occur:

- Any person with access leaves the project or the organisation
- A client access engagement ends
- A credential is suspected to have been compromised
- At minimum every 90 days for any environment active beyond that period

The IT Manager must be notified of any rotation triggered by a departure or suspected compromise. All rotations must be recorded in the Environment Register.

8. PHASE 5 — ONGOING MAINTENANCE AND MONITORING

8.1 Software Updates

CMS platforms, plugins, and themes must be kept current throughout the environment lifecycle. Any environment running software with known unpatched vulnerabilities must not remain publicly accessible. The Webmaster must apply updates or take the environment offline pending patching and must notify the IT Manager of any suspension.

8.2 Periodic Access Reviews

For any environment active beyond 30 days the Webmaster must conduct a formal access review every 30 days, confirming all access holders still require access. Findings must be submitted to the IT Manager. Any unjustified access must be revoked immediately.

8.3 Log Retention

cPanel server access logs and error logs for all dev/staging environments must be retained for a minimum of 90 days. Log retention constitutes personal data processing under the JDPA 2020 and is maintained on the basis of the organisation's legitimate interest in security monitoring. The DPO must confirm that 90-day retention is proportionate to that purpose and that it is reflected in the organisation's data processing register and Privacy Notice. Logs must not be manually cleared or purged within this window. In the event of a security incident, logs must be preserved beyond 90 days until the Security Officer confirms the investigation is closed. Where a security incident has been or is being considered for referral to law enforcement, log destruction must not proceed without written confirmation from the organisation's legal advisers that no legal hold, court order, or investigation obligation prevents destruction.

8.4 Vulnerability Scanning

All active dev/staging environments must undergo a basic automated vulnerability scan at provisioning and at minimum every 60 days thereafter. For WordPress environments, WPScan or an equivalent approved tool must be used. High or critical findings must be reported to the IT Manager and Security Officer within 24 hours of scan completion. Environments with unresolved critical vulnerabilities must be taken offline until remediated.

8.5 Security Officer Spot-Checks

The Security Officer must conduct independent unannounced spot-checks on a sample of active environments at least once per quarter. Findings must be reported to the Director and IT Manager in writing within 5 business days of the check.

9. PHASE 6 — THE 30-DAY POST-LAUNCH REVIEW

When a project goes live the web developer must notify the Webmaster in writing on the same day. The Webmaster must conduct the post-launch review and submit findings to the IT Manager within 30 days of the production launch date. The review must assess whether there is a documented ongoing need for the environment, whether all controls remain in place, whether any live data is present that should not be, and whether all access grants remain appropriate.

Default outcome is decommissioning. If no ongoing need is documented the IT Manager must authorise decommissioning and the Webmaster must execute within 5 business days.

Missed review escalation: If findings are not submitted by day 30 the environment must be automatically suspended and the IT Manager notified. The environment remains suspended until the review is completed and a decision is issued.

Continuation: Requires the IT Manager's explicit written approval with a new review date. No environment may be continued beyond 180 days from its original creation date without being fully rebuilt from scratch. The Webmaster must flag environments approaching the 180-day limit to the IT Manager at least 14 days in advance.

10. PHASE 7 — DECOMMISSIONING

Decommissioning requires IT Manager written authorisation. Once authorised the Webmaster must complete all of the following and confirm completion to the IT Manager, Security Officer, and DPO (where personal data was involved) in writing:

1. Notify all access holders with a minimum of 48 hours notice unless a security incident requires immediate action
2. Verify no live or personal data remains in the database or file system
3. Permanently delete all environment databases from cPanel — dropping tables is insufficient
4. Delete all environment files including uploads, logs, backups, and configuration files, ensuring deletion is permanent and not recoverable
5. Remove all cPanel sub-accounts, FTP accounts, email accounts, and access credentials
6. Remove all IP restriction rules and client access exceptions
7. REMOVE THE SUBDOMAIN DNS RECORD from cPanel's DNS zone — a lingering record creates a subdomain takeover risk
8. REVOKE OR CLEAN UP any SSL certificate issued for the staging subdomain and confirm the subdomain is no longer active under any wildcard certificate
9. Update the Environment Register with the decommission date, executing party, and confirmation that DNS and certificates have been cleaned up
10. Confirm full decommissioning in writing to the IT Manager, Security Officer, and DPO where the environment handled personal data at any point

11. ENVIRONMENT REGISTER

The Webmaster maintains the Environment Register covering all active and recently decommissioned environments. It must be available to the IT Manager, Security Officer, and DPO at all times and reviewed by the Webmaster monthly.

Field	Detail
Environment Name	
Risk Classification	Standard / Elevated / High
Project / Client	
Requesting Developer	
Date Requested	
IT Manager Approval Date	
Data Classification	Synthetic only / Live data exception
Live Data Exception Detail	Dates, scope, approvals, deletion confirmed
Client Access	Name, access level, approval date, expiry
IP Restriction Exception	Reason and expiry
90-Day Credential Rotation Dates	
Production Launch Date	
30-Day Review Submission Date	
IT Manager Review Decision	Continue / Decommission
Continuation Expiry / Rebuild Date	
180-Day Limit Date	
Date Decommissioned	
Decommissioned By	
DNS Record Removed	Yes / No
SSL Cleaned Up	Yes / No
DPO Notified of Decommission	Yes / No / N-A

12. SECURITY INCIDENT RESPONSE — IDENTIFICATION AND HANDOFF TO IRP

12.1 Relationship to the Incident Response Plan

This procedure governs identification and immediate reporting of security incidents involving dev/staging environments. Once reported, the IT Manager activates the organisation's IT/Cybersecurity Incident Response Plan, which governs all subsequent steps — investigation, containment, recovery, JDPA notification, law enforcement referral, and post-incident review. This procedure does not duplicate the IRP. Where an incident involves personal data the DPO is engaged by the IT Manager in accordance with the IRP.

12.2 What Constitutes a Triggerable Incident

The following events must trigger this incident response process (this list is illustrative, not exhaustive):

- Unexpected or unauthorised user accounts found in a CMS or cPanel
- Suspicious login attempts or login spikes in access logs
- Files found on the server that were not placed there by the team
- Any environment becoming publicly accessible without authentication
- Live or personal data found in an environment where it should not be present
- A client reporting unexpected access, content, or behaviour
- Any dev/staging environment indexed or appearing in search engine results
- Any suspected compromise of credentials used to access an environment

12.3 Immediate Response Steps

1. Any staff member who identifies or suspects a security incident must report it to the IT Manager immediately
2. The IT Manager activates the Incident Response Plan and notifies all parties in accordance with it
3. All further steps — containment, investigation, JDPA notification, and recovery — are governed by the Incident Response Plan from the point of IT Manager activation
4. No environment may be modified, cleaned up, or decommissioned until authorised by the IT Manager under the Incident Response Plan — all evidence must be preserved
5. 12.4 Notification Summary

Who	Notified By	Timeframe
IT Manager	Any staff member who identifies a suspected incident	Immediately

All further parties	IT Manager (per Incident Response Plan)	Per IRP timelines

13. TRAINING AND ACKNOWLEDGEMENT

13.1 Mandatory Training

All staff covered by this procedure must complete mandatory training before being granted access to any dev/staging environment for the first time. Training must cover all key controls, data handling obligations, JDPA requirements, the synthetic data standard, and incident reporting responsibilities including the 72-hour clock obligation. Training must also cover: awareness of the Cybercrimes Act 2015, including that unauthorised access to, modification of, or interference with computer data is a criminal offence regardless of employment status; and notification to staff that their system access activity is logged, that logs are retained for 90 days, and that logs may be reviewed in the context of a security investigation or disciplinary process. This notification constitutes the organisation's pre-monitoring disclosure for the purposes of the JDPA 2020 and must be captured in the Section 13.2 acknowledgement.

13.2 Acknowledgement

Each staff member must sign a written acknowledgement confirming they have read, understood, and agree to comply with this procedure. Signed acknowledgements must be retained by the IT Manager. No environment access may be granted until the acknowledgement is on file. The acknowledgement does not constitute a variation of the employee's contract of employment. Where an employee declines to sign, the matter must be referred to HR for resolution through the employment relations process; access must not be granted until the matter is resolved, but the employee must not face automatic disciplinary action for declining without further process.

13.3 Refresher Training

Refresher training must be completed annually by all in-scope staff and whenever a new version of this procedure is issued. Training records must be maintained by the IT Manager. Transitional provision: staff who were performing functions covered by this procedure prior to its effective date must complete mandatory training within 60 days of that date. During this period their existing access is conditional on training being formally scheduled and confirmed with the IT Manager. Existing access does not constitute a waiver of the training requirement.

13.4 Client Briefing

Clients receiving conditional access must be briefed in writing before access is granted, covering the non-production nature of the environment, prohibition on sharing credentials, prohibition on publicly

referencing the environment, and the obligation to report unexpected behaviour immediately to the Webmaster.

14. EXCEPTION AND WAIVER PROCESS

Informal deviations from this procedure are not permitted under any circumstances. The following process governs all legitimate operational exceptions:

1. The requesting staff member submits a written waiver request to the Webmaster describing the specific control, the operational justification, any proposed alternative control, and the requested duration
2. The Webmaster forwards to the Security Officer for a written technical risk assessment
3. Where the waiver involves any data handling control the Webmaster must also notify the DPO for an independent data protection assessment
4. The Security Officer provides a recommendation to the IT Manager
5. Only the IT Manager may approve a waiver — the Security Officer may recommend but not approve
6. Approved waivers must be time-limited, recorded in the Environment Register, and reviewed at expiry
7. The Director must be notified of any approved waiver
8. No waiver may be approved that would result in a breach of the Jamaica Data Protection Act 2020 — the DPO's assessment on this point is binding

15. HOSTING PROVIDER RESPONSIBILITIES AND SECURITY BOUNDARY

The organisation procures shared cPanel hosting from a third-party provider. The following defines the security boundary between provider and organisational responsibilities.

Hosting Provider Responsibilities	Organisation Responsibilities
Physical security of the data centre and server hardware	All security controls at the cPanel account level and above
Hypervisor-level isolation between hosting accounts	All application, CMS, database, and file-level security
Network-level DDoS mitigation and infrastructure security	All access management for hosting accounts and environments
Security and patching of the cPanel platform itself	All data handling within hosted environments
Issuing security advisories and notifications for the platform	Full JDPA 2020 compliance for all data within hosted environments
	Monitoring and acting on hosting provider security advisories

The Webmaster is responsible for maintaining the day-to-day relationship with the hosting provider, receiving and distributing security advisories to the IT Manager, Security Officer, and DPO as appropriate, and escalating directly to the provider when a platform-level security issue is suspected.

The IT Manager must be notified immediately whenever the Webmaster raises an escalation with the hosting provider. The Security Officer and DPO must both be notified of any advisory that may affect hosted environments or involve personal data. In the event of a suspected platform-level breach, the Incident Response Plan must be activated, the Director notified immediately, and the DPO engaged where personal data may be affected.

The organisation must maintain a signed Data Processing Agreement with the hosting provider that identifies the provider as a data processor, sets out the categories of personal data processed, requires the provider to implement appropriate technical and organisational security measures, and prohibits the provider from using personal data for any purpose beyond the provision of hosting services.

The IT Manager must confirm annually that the hosting provider's contractual obligations and any independently verified security certifications (such as ISO 27001 or SOC 2) support the responsibilities attributed to the provider in the table above. Where the provider's contract is silent or weaker than assumed, the residual risk must be documented in the organisation's risk register.

16. NON-COMPLIANCE

Failure to follow this procedure — including creating an environment without approval, placing live data in a dev/staging environment without authorisation, granting or receiving access outside the approved process, or failing to decommission an environment as directed — is a serious breach of organisational IT security policy.

Depending on the nature and severity, non-compliance may result in disciplinary action in accordance with the organisation's Disciplinary Procedure and the requirements of Jamaican employment law, up to and including termination where the conduct constitutes gross misconduct. Disciplinary action will follow the organisation's disciplinary process in all cases — no sanction follows automatically from any specific breach without due process.

This procedure is incorporated by reference into all relevant staff contracts of employment and forms part of the organisation's disciplinary and conduct framework. Where personal data has been exposed, ordinary operational non-compliance is addressed through the internal disciplinary process. Wilful, reckless, or criminally negligent mishandling of personal data may, in serious cases, attract personal legal consequence under the JDPA 2020 or the Cybercrimes Act 2015 — however this applies only to conduct that goes beyond ordinary negligence. The organisation bears primary liability as data controller for data protection compliance.

17. DOCUMENT APPROVAL AND REVIEW

This procedure must be reviewed annually. The Security Officer reviews from a cybersecurity standpoint, the DPO reviews from a data protection standpoint, the IT Manager approves operationally, and the Director signs off before the procedure takes effect. The DPO's data protection recommendations must be addressed before the Director provides sign-off. This procedure is not operative until all signatures below are completed and an Effective Date is recorded. Until that date it must be treated as a draft and must not be distributed, enforced, or relied upon as evidence of the organisation's security compliance framework. Upon signing, the Effective Date recorded below is the date from which all obligations in this procedure become binding on all named roles.

Role	Name	Signature	Date
Effective Date (procedure operative from this date)			
Director / Deputy CEO			
IT Manager			
Security Officer			
Data Protection Officer			
Webmaster			

APPENDIX A — ENVIRONMENT REQUEST FORM

To be completed by the requesting web developer and submitted to the Webmaster. Freeform requests will not be taken.

Field	Response
Developer Name	
Date of Request Project Name	
Client Name	
Purpose of Environment Risk Classification Expected Duration	Standard / Elevated / High
Live Data Exception Required? If Yes — reason synthetic data is insufficient	Yes / No — If Yes, a separate written exception request must be submitted simultaneously under Section 6.3. This field does not initiate the exception process.
Names and roles of all staff requiring access Client Access Required? If Yes — client name, contact, and access level	Yes / No
IP Restriction Exception Required?	Yes / No — reason and duration
Developer Signature	
Date	

APPENDIX B — CLIENT ACCESS AGREEMENT

To be signed by the approved client before access is granted.

I, the undersigned, acknowledge that I have been granted conditional, time-limited access to a staging web environment managed by [Organisation Name] for the sole purpose of reviewing work in progress on the above-named project.

I understand and agree that:

- This is not a live production environment
- My access credentials are personal to me and must not be shared with any other person
- I must not link to, publicly reference, or share the URL of this environment with any third party
- I must not attempt to access any part of the environment beyond my defined review role
- I must report any unexpected content, access issues, or security concerns immediately to the Webmaster
- My access will expire on the date specified below and will be revoked at that time
- I undertake to keep strictly confidential all information, data, content, and materials I encounter in this environment. I must not copy, download, screenshot, forward, or otherwise extract any information from this environment. I must report any inadvertent download or unintended exposure of any information to the Webmaster within 24 hours of becoming aware. This confidentiality obligation survives the expiry of my access and the completion of the project

Field	Detail
Client Name	
Organisation	
Project Name	
Access Level Granted	
Access Expiry Date	
Client Signature	
Date Signed	
Webmaster — Access Confirmed (operational record only — not a contractual counterparty)	Signature / Date
IT Manager — Authorised Signatory (on behalf of the organisation) — Name / Signature / Date	
Client — Signing on behalf of (Company Name)	
Client — Company Registration Number	

Client — Capacity / Authority (e.g. Director, Authorised Signatory)	
Client warrants they have authority to bind the company named above to these access conditions	By signing above the client confirms this warranty
Governing Law and Jurisdiction: These access conditions are governed by the laws of Jamaica. The parties submit to the non-exclusive jurisdiction of the Jamaican courts for the resolution of any dispute arising under or in connection with these conditions.	

— End of Document — IT-SEC-002 v2.6